

SECURITY & GOVERNANCE

Build it secure.

Build it responsibly.

THE CORE IDEA

Security is an architecture decision - not a feature you add at the end.

Design who can access the solution, what data it touches, what it can do, how it is monitored, and who remains accountable.

01

IDENTITY

02

DATA

03

ACCESS

04

MONITOR

05

AI

06

GOVERN

Start with Zero Trust

Microsoft describes Zero Trust as a security strategy - not a product.

01

VERIFY EXPLICITLY

Authenticate and authorize using the available identity, device, location, risk, and resource context.

02

USE LEAST PRIVILEGE

Give users, apps, and services only the access they need - and no more.

03

ASSUME BREACH

Design to limit blast radius, segment access, encrypt, monitor, and recover when something goes wrong.

ASK YOUR TEAM

If one account, API key, or component is compromised, what can it reach?

Your architecture should have a deliberate answer.

Identity is the new perimeter

Design access before you design convenience.

01 WHO IS THE USER?

Use trusted identity and modern authentication. Avoid building your own password system when an identity platform can handle it.

02 WHAT SHOULD THEY DO?

Use roles and permissions. A viewer should not automatically have admin or write access.

03 WHAT SHOULD THE APP DO?

Services and agents need identities too. Do not give an application broad permissions just because it is easier.

04 WHERE ARE THE SECRETS?

Never hard-code credentials, API keys, tokens, or connection strings in source code or prompts.

05 WHAT IS PRIVILEGED?

Treat administrative actions differently. Require stronger controls for high-impact operations.

06 WHAT HAPPENS WHEN ACCESS CHANGES?

Plan for revocation, expiration, role changes, and compromised credentials.

MICROSOFT EXAMPLE

Microsoft Entra can provide identity, authentication, Conditional Access, and role-based controls.

Protect the data journey

Know what data enters, where it goes, who can see it, and how long it stays.

COLLECT

Do we actually need this data?

Minimize unnecessary personal or sensitive information.

CLASSIFY

How sensitive is it?

Identify confidential, personal, regulated, or business-critical data.

PROTECT

How is it secured?

Encrypt data in transit and at rest; control access and protect keys.

USE

Who or what can process it?

Respect purpose, permissions, boundaries, and customer expectations.

RETAIN

How long should it exist?

Avoid keeping data forever by default. Define retention and deletion.

MICROSOFT EXAMPLE

Microsoft Purview supports data governance, classification, and sensitivity labeling.

The product is not the principle: first understand and govern the data.

Secure systems are observable

If something goes wrong, your team should be able to detect it, understand it, and respond.

LOG

Capture important access, changes, failures, and privileged actions.

WATCH OUT

Do not put secrets or sensitive personal data into logs.

DETECT

Look for abnormal behavior, vulnerabilities, misconfiguration, and threats.

WATCH OUT

Security posture should be continuously evaluated.

RESPOND

Define who owns an issue and what happens when a control fails.

WATCH OUT

A finding without ownership is not governance.

IMPROVE

Use incidents, recommendations, and testing to strengthen the design.

WATCH OUT

Security is an operating cycle, not a launch checkbox.

MICROSOFT EXAMPLES

Defender for Cloud can assess security posture; Azure Policy can enforce governance rules and standards.

AI adds new responsibilities

Responsible AI must be designed into the architecture - especially when a system can generate, recommend, or act.

FAIRNESS

Could performance or outcomes differ unfairly across people or groups?

RELIABILITY & SAFETY

What happens when the model is wrong, uncertain, manipulated, or outside its intended scope?

PRIVACY & SECURITY

What information can the AI access, retain, expose, or infer?

INCLUSIVENESS

Can different users meaningfully and safely use the experience?

TRANSPARENCY

Do users understand that AI is involved, what it can do, and its limitations?

ACCOUNTABILITY

Who owns the system's behavior, approvals, monitoring, and outcomes?

FOR AGENTS & AUTOMATION

Define what the AI is allowed to know, decide, and do - and where a human must approve.

Microsoft capabilities you may encounter

Use products to implement the security decision - not to replace the decision.

MICROSOFT ENTRA

IDENTITY & ACCESS

Authentication, Conditional Access, roles, workload identities.

MICROSOFT PURVIEW

DATA GOVERNANCE

Classification, sensitivity, information protection, governance.

MICROSOFT DEFENDER

THREAT PROTECTION

Security posture, vulnerability and threat detection across workloads.

AZURE POLICY

CLOUD GOVERNANCE

Define and assess rules for how Azure resources should be configured.

KEY VAULT

SECRETS & KEYS

Protect secrets, keys, and certificates instead of embedding them in code.

MICROSOFT FOUNDRY

AI SAFETY & EVALUATION

Build and evaluate AI solutions with safety, governance, and Responsible AI considerations.

REMEMBER

A secure architecture can use many products. The principles should remain understandable without them.

Before you build. Before you demo.

Use this as a lightweight security design review with your team.

☐**IDENTITY**

Do we know who should access the solution?

☐**PERMISSIONS**

Are users, services, and agents limited to what they actually need?

☐**SECRETS**

Are credentials and keys protected rather than embedded in code?

☐**DATA**

Do we know what data we collect, where it goes, and how sensitive it is?

☐**PRIVACY**

Are we minimizing unnecessary personal or confidential information?

☐**ENCRYPTION**

Is sensitive data protected in transit and at rest?

☐**LOGGING**

Can we understand important access, failures, and changes without logging secrets?

☐**FAILURE**

What happens if a component, identity, or AI output is compromised or wrong?

☐**AI GUARDRAILS**

If AI is involved, are its scope, limitations, human oversight, and safety controls clear?

☐**OWNERSHIP**

Who is accountable for security findings, approvals, and remediation?

☐**GOVERNANCE**

Can the design be reviewed against policies and standards?

☐**DEMO SAFETY**

Are we using safe demo data and avoiding exposure of credentials or real sensitive information?

THE TEST

Can your team explain how the solution protects the customer -
not just what the solution does?